

Vendor Risk Radar

Security Risk Report - Okta

Generated: 2026-04-29 17:39 UTC

Risk Score: 26/100 - CRITICAL RISK

CVEs Analyzed: 15

Actively Exploited (KEV): 0

CVE Analysis

CVE ID	CVSS	Category	KEV	Description
CVE-2021-28113	6.7	Privilege Escalation	no	a command injection vulnerability in the cookiedomain and relaydomain ...
CVE-2022-24295	8.8	Injection	no	okta advanced server access client for windows prior to version 1.57.0...
CVE-2022-1030	8.8	Injection	no	okta advanced server access client for linux and macos prior to versio...
CVE-2022-23170	5.9	Auth Bypass	no	sysaid - okta sso integration - was found vulnerable to xml external e...
CVE-2022-1697	3.9	Other	no	okta active directory agent versions 3.8.0 through 3.11.0 installed th...
CVE-2022-3145	4.7	Misconfig	no	an open redirect vulnerability exists in okta oidc middleware prior to...
CVE-2023-0093	8.8	Injection	no	okta advanced server access client versions 1.13.1 through 1.65.0 are ...
CVE-2024-1900	5.5	Auth Bypass	no	improper session management in the identity provider authentication fl...
CVE-2024-0980	7.1	Rce	no	the auto-update service for okta verify for windows is vulnerable to t...
CVE-2024-0981	7.1	Injection	no	okta browser plugin versions 6.5.0 through 6.31.0 (chrome/edge/firefox...
CVE-2024-7061	5.5	Privilege Escalation	no	okta verify for windows is vulnerable to privilege escalation through ...
CVE-2024-10327	8.1	Other	no	a vulnerability in okta verify for ios versions 9.25.1 (beta) and 9.27...

Risk Score Breakdown

CVE ID	Category	CVSS	KEV	Penalty
CVE-2024-0980	Rce	7.1	no	-10.22
CVE-2024-9191	Auth Bypass	7.1	no	-9.09
CVE-2024-9875	Privilege Escalation	7.1	no	-8.52
CVE-2024-0981	Injection	7.1	no	-7.38
CVE-2024-10327	Other	8.1	no	-6.48
CVE-2022-24295	Injection	8.8	no	-6.41
CVE-2022-1030	Injection	8.8	no	-6.41
CVE-2023-0093	Injection	8.8	no	-6.41

Risk Narrative

Okta's overall security posture is concerning, with a critical risk score of 26/100, indicating a high level of vulnerability to potential attacks. The analysis of 15 CVEs reveals a pattern of injection and privilege escalation vulnerabilities, which could be exploited by malicious actors to gain unauthorized access to sensitive systems and data. The absence of any known exploited vulnerabilities (KEV) in the CISA catalog is somewhat reassuring, but the high CVSS scores associated with several of the analyzed CVEs, such as CVE-2022-24295 and CVE-2022-1030, both with scores of 8.8, suggest that the potential impact of a successful attack could be severe.

Specific attack scenarios based on the analyzed CVEs are alarming, as they reveal potential pathways for malicious actors to exploit Okta's vulnerabilities. For instance, an attacker could leverage the command injection vulnerability in CVE-2021-28113 to escalate privileges and gain control over the Okta access gate, potentially allowing them to authenticate as any user. Similarly, the injection vulnerabilities in CVE-2022-24295 and CVE-2022-1030 could be exploited to inject malicious code into the Okta advanced server access client, potentially allowing an attacker to execute arbitrary commands on vulnerable systems. Additionally, the XML external entity injection vulnerability in CVE-2022-23170 could be used to bypass authentication mechanisms and gain unauthorized access to sensitive data. These scenarios highlight the need for urgent remediation and mitigation efforts to prevent potential attacks.

To mitigate the identified risks, it is essential to prioritize patching and updating Okta's software and systems to the latest versions, ensuring that all known vulnerabilities are addressed. Specifically, updating the Okta advanced server access client to version 1.57.0 or later for Windows, and version 1.58.0 or later for Linux and macOS, would help to remediate the injection vulnerabilities in CVE-2022-24295 and CVE-2022-1030. Additionally, implementing robust input validation and sanitization measures can help to prevent command injection attacks, such as those associated with CVE-2021-28113. Furthermore, conducting regular security audits and penetration testing can help to identify and address potential vulnerabilities before they can be exploited by malicious actors. By taking these concrete steps, we can reduce the risk of a successful attack and protect our systems and data from potential threats.